

3

Lab

PHỤC VỤ MỤC ĐÍCH GIÁO DỤC
FOR EDUCATIONAL PURPOSE ONLY

QUÉT LỖ HỔNG BẢO MẬT

Vulnerability Scanning

Thực hành môn An toàn Mạng máy tính

Tháng 10/2021

Lưu hành nội bộ

<Nghiêm cấm đăng tải trên internet dưới mọi hình thức>

Mọi góp ý về tài liệu, vui lòng gửi về email khoanh@uit.edu.vn



A. TỔNG QUAN

1. Mục tiêu

- Hiểu và sử dụng thành thạo các công cụ quét lỗ hổng tự động như Nessus, OpenVAS và Nmap.

2. Thời gian thực hành

- Thực hành tại lớp: **5** tiết tại phòng thực hành.
- Hoàn thành báo cáo kết quả thực hành: tối đa **13** ngày.

3. Kiến thức nền tảng

Phát hiện lỗ hổng bảo mật là một phần không thể thiếu trong quá trình đánh giá bảo mật. Mặc dù chúng ta thích các tác vụ thủ công, chuyên biệt, tận dụng kiến thức và kinh nghiệm của chúng tôi trong quá trình kiểm tra bảo mật, nhưng các công cụ quét lỗ hổng bảo mật tự động vẫn có giá trị khi được sử dụng trong ngữ cảnh thích hợp. Trong bài thực hành này, sinh viên sẽ có cái nhìn tổng quan về quét lỗ hổng bảo mật tự động, thảo luận về các cân nhắc khác nhau của nó và tập trung vào cả Nessus và OpenVAS như những công cụ không thể thiếu.

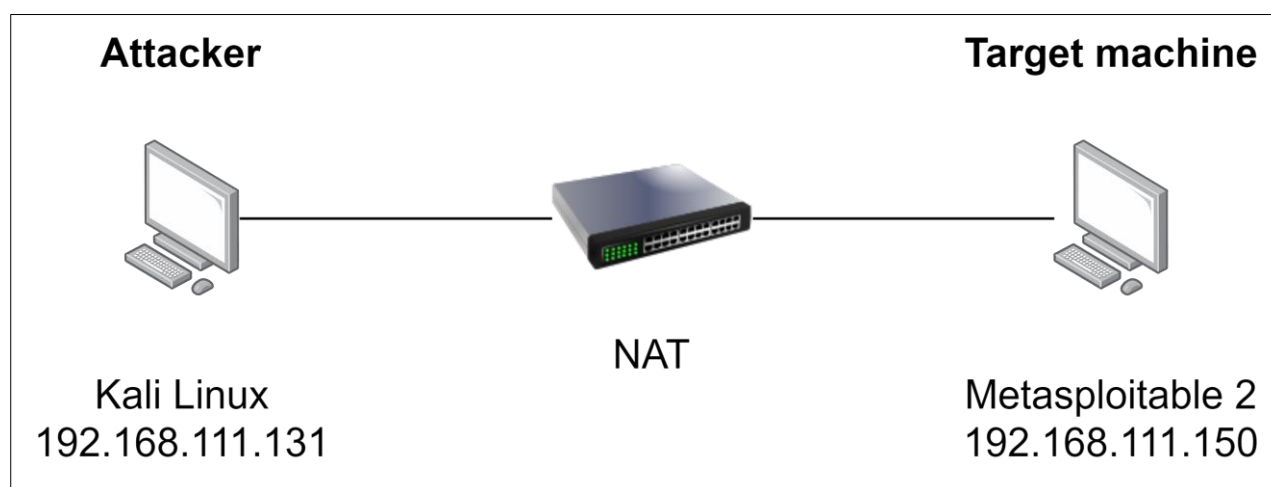
4. Môi trường thực hành

Sinh viên cần chuẩn bị trước máy tính với môi trường thực hành như sau:

Bài thực hành này sẽ sử dụng máy ảo Kali Linux đã được triển khai ở Lab 1.

Metasploitable 2 có địa chỉ IP **192.168.111.150** (VMNet 8 – NAT)

(<http://downloads.metasploit.com/data/metasploitable/metasploitable-linux-2.0.0.zip>)



Hình 1. Mô hình mạng bài thực hành

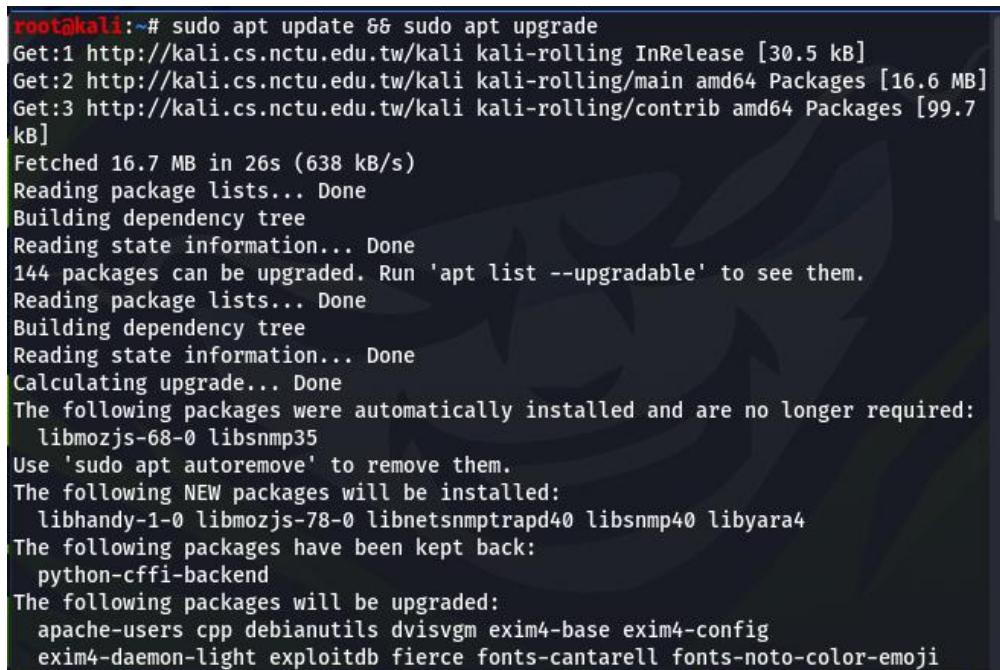
B. THỰC HÀNH

1. Quét lỗ hổng sử dụng công cụ Nessus

Nessus là một công cụ quét lỗ hổng phổ biến, hỗ trợ hơn 130000 plugin. Ban đầu, Nessus được phát triển như một ứng dụng mã nguồn mở, tuy nhiên, năm 2005, mã nguồn đã được đóng. Sự thay đổi đối với mô hình nguồn đóng dẫn đến các nhánh của dự án mã nguồn mở được phát triển, và một trong số đó là OpenVAS.

a) Cài đặt Nessus

Trước khi cài đặt, đảm bảo máy Kali Linux luôn ở phiên bản mới nhất:



```
root@kali:~# sudo apt update && sudo apt upgrade
Get:1 http://kali.cs.nctu.edu.tw/kali kali-rolling InRelease [30.5 kB]
Get:2 http://kali.cs.nctu.edu.tw/kali kali-rolling/main amd64 Packages [16.6 MB]
Get:3 http://kali.cs.nctu.edu.tw/kali kali-rolling/contrib amd64 Packages [99.7 kB]
Fetched 16.7 MB in 26s (638 kB/s)
Reading package lists... Done
Building dependency tree
Reading state information... Done
144 packages can be upgraded. Run 'apt list --upgradable' to see them.
Reading package lists... Done
Building dependency tree
Reading state information... Done
Calculating upgrade... Done
The following packages were automatically installed and are no longer required:
  libmozjs-68-0 libsnmp35
Use 'sudo apt autoremove' to remove them.
The following NEW packages will be installed:
  libhandy-1-0 libmozjs-78-0 libnetsnmptrapd40 libsnmp40 libyara4
The following packages have been kept back:
  python-cffi-backend
The following packages will be upgraded:
  apache-users cpp debianutils dvisvgm exim4-base exim4-config
  exim4-daemon-light exploitdb fierce fonts-cantarell fonts-noto-color-emoji
```

Hình 2. Đảm bảo máy Kali Linux được cập nhật phần mềm mới nhất

Mặc dù Nessus không có trong repository của Kali, chúng ta có thể tải về tập tin 64-bit **.deb** tại trang chủ của Tenable: <https://www.tenable.com/downloads/nessus>

Chúng ta có thể kiểm tra giá trị checksum MD5 hoặc SHA256 bằng cách bấm vào liên kết “Checksum” (Hình 3)

Nessus - 8.12.0

View Release Notes

Nessus-8.12.0-ubuntu910_amd64.deb	Ubuntu 9.10 / Ubuntu 10.04 (64-bit)	42.3 MB	Oct 8, 2020	Checksum
Nessus-8.12.0-Win32.msi	Windows 7, 8, 10 (32-bit)	71.2 MB	Oct 8, 2020	Checksum
Nessus-8.12.0.dmg	macOS (10.9 - 10.15)	41.8 MB	Oct 8, 2020	Checksum
Nessus-8.12.0-amzn.x86_64.rpm	Amazon Linux 2015.03, 2015.09, 2017.09 / Amazon Linux 2	42.5 MB	Oct 8, 2020	Checksum
Nessus-8.12.0-amzn2.aarch64.rpm	Amazon Linux 2			
Nessus-8.12.0-debian6_amd64.deb	Debian 6, 7, 8, 9 / Kali Linux 1, 2017.3, 2018, 2019, 2020 AMD64	42.3 MB	Oct 8, 2020	Checksum
Nessus-8.12.0-debian6_i386.deb	Debian 6, 7, 8, 9 / Kali Linux 1, 2017.3 i386(32-bit)	40.1 MB	Oct 8, 2020	Checksum

Hình 3. Tải Nessus-8.12.0-debian6_amd64.deb và kiểm tra checksum

Sau khi tải về, kiểm tra tính toàn vẹn của tập tin bằng lệnh **md5sum** (đối với giá trị MD5) hoặc **sha256sum** (đối với giá trị SHA256), đảm bảo giá trị của tập tin này trùng khớp với giá trị được công bố trên trang chủ.

```
root@kali:~# file Nessus-8.12.0-debian6_amd64.deb
Nessus-8.12.0-debian6_amd64.deb: Debian binary package (format 2.0), with control.tar.gz, data compression gz
root@kali:~# md5sum Nessus-8.12.0-debian6_amd64.deb
622699b804cbb472852f297e37432e75 Nessus-8.12.0-debian6_amd64.deb
root@kali:~# sha256sum Nessus-8.12.0-debian6_amd64.deb
7b30df876ccfc9f260d09818ab977820f2997d1402bd01bd5c1b1c83edc77661 Nessus-8.12.0-debian6_amd64.deb
root@kali:~#
```

Hình 4. Kiểm tra tính toàn vẹn của tập tin vừa tải về

Sau khi đảm bảo tính toàn vẹn được bảo toàn trong quá trình tải tập tin về máy, thực hiện cài đặt bằng lệnh **apt**:

```

root@kali:~# sudo apt install ./Nessus-8.12.0-debian6_amd64.deb
Reading package lists... Done
Building dependency tree
Reading state information... Done
Note, selecting 'nessus' instead of './Nessus-8.12.0-debian6_amd64.deb'
The following packages were automatically installed and are no longer required:
  libmozjs-68-0 libsnmp35
Use 'sudo apt autoremove' to remove them.
The following NEW packages will be installed:
  nessus
0 upgraded, 1 newly installed, 0 to remove and 1 not upgraded.
Need to get 0 B/42.3 MB of archives.
After this operation, 0 B of additional disk space will be used.
Get:1 /root/Nessus-8.12.0-debian6_amd64.deb nessus amd64 8.12.0 [42.3 MB]
Selecting previously unselected package nessus.
(Reading database ... 424411 files and directories currently installed.)
Preparing to unpack .../Nessus-8.12.0-debian6_amd64.deb ...
Unpacking nessus (8.12.0) ...
Setting up nessus (8.12.0) ...
Unpacking Nessus Scanner Core Components...

- You can start Nessus Scanner by typing /bin/systemctl start nessusd.service
- Then go to https://kali:8834/ to configure your scanner

```

Hình 5. Cài đặt Nessus

Sau khi cài đặt thành công, thực hiện khởi động dịch vụ *nessusd*

```

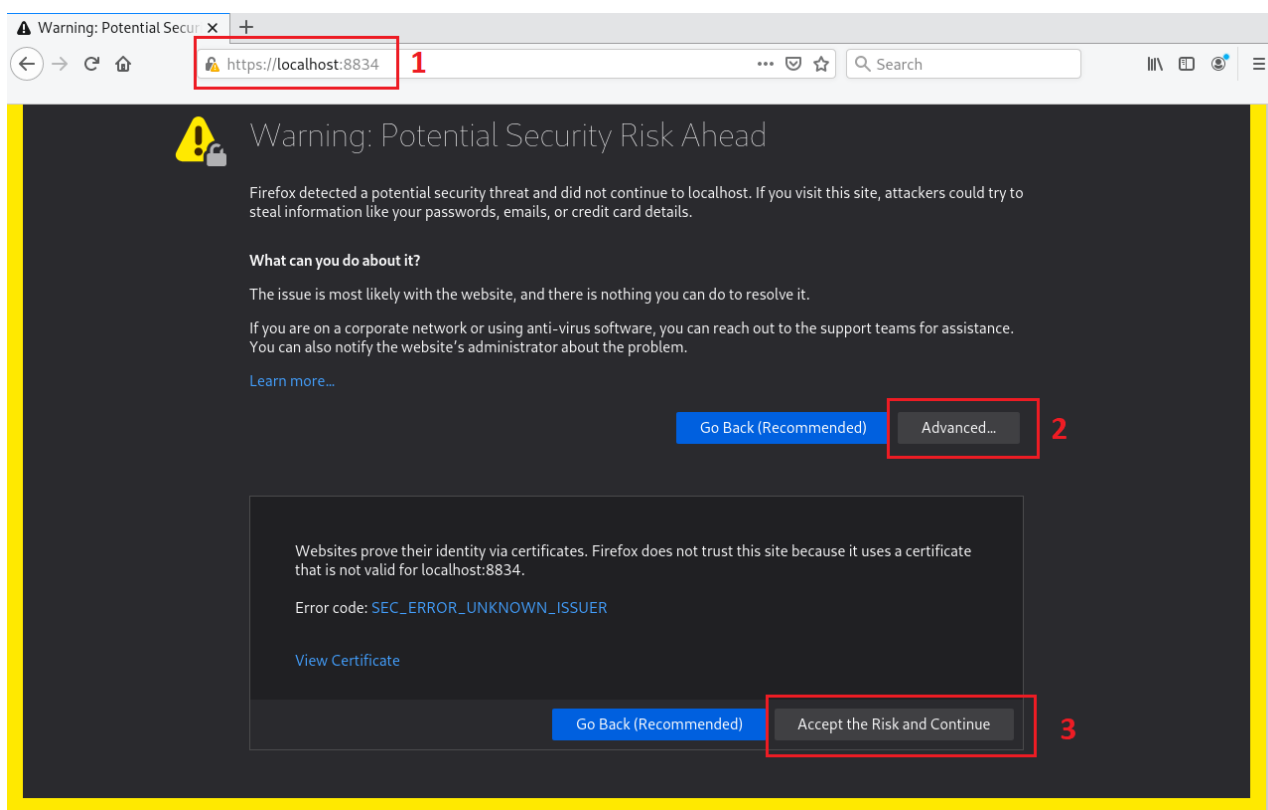
root@kali:~# /bin/systemctl start nessusd.service
root@kali:~# systemctl status nessusd
● nessusd.service - The Nessus Vulnerability Scanner
   Loaded: loaded (/lib/systemd/system/nessusd.service; disabled; vendor preset: >
   Active: active (running) since Sun 2020-10-11 08:25:20 EDT; 18s ago
   Main PID: 18102 (nessus-service)
      Tasks: 12 (limit: 4602)
     Memory: 133.7M
    CGroup: /system.slice/nessusd.service
            └─18102 /opt/nessus/sbin/nessus-service -q
              18103 nessusd -q

Oct 11 08:25:20 kali systemd[1]: Started The Nessus Vulnerability Scanner.
lines 1-11/11 (END)

```

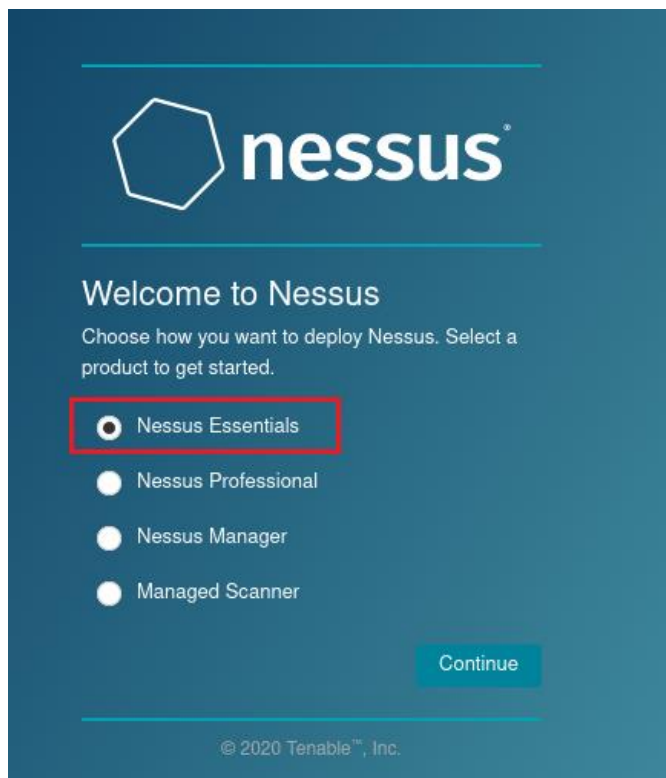
Hình 6. Khởi động dịch vụ *nessusd*

Sau khi khởi động Nessus, mở trình duyệt và truy cập vào đường dẫn <https://localhost:8834/>. Chúng ta sẽ được thông báo lỗi certificate, chọn *Advanced...*
 -> *Accept the Risk and Continue*



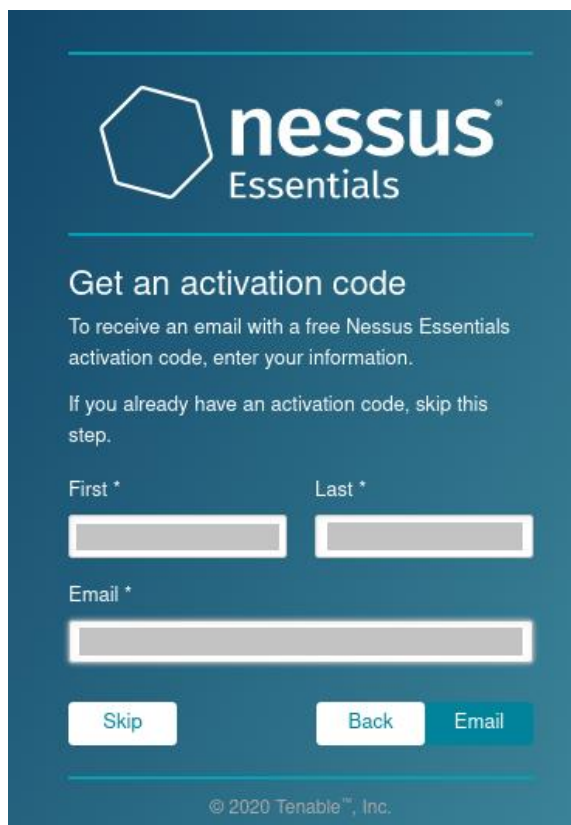
Hình 7. Bỏ qua lỗi certificate

Sau khi trang được tải lên, chúng ta được thông báo chọn phiên bản Nessus muốn sử dụng. Trong trường hợp này, chọn *Nessus Essentials*, sau đó chọn *Continue*



Hình 8. Chọn phiên bản Nessus Essentials

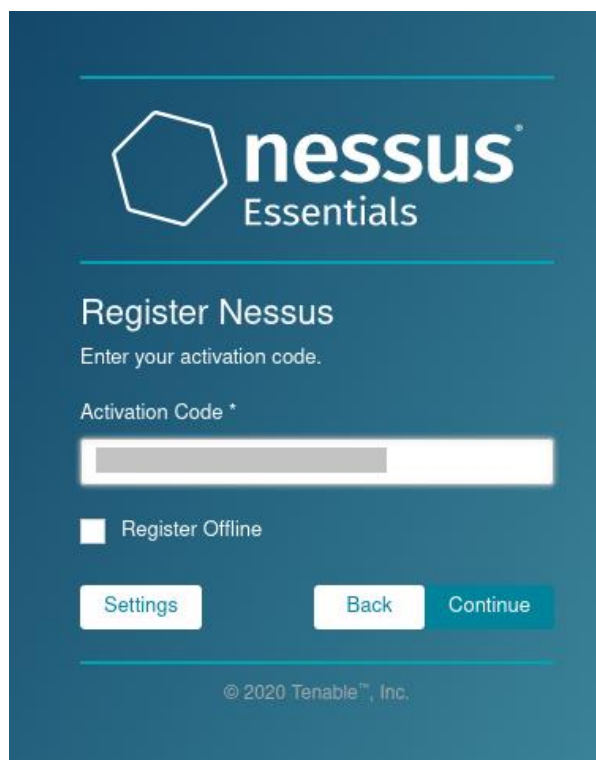
Tiếp theo, nhập các thông tin theo yêu cầu. Lưu ý, nhập đúng địa chỉ email để Nessus có thể gửi Activation code về hòm thư điện tử, sau đó nhấn *Email*



The screenshot shows the Nessus Essentials registration interface. At the top is the Nessus Essentials logo. Below it, the heading 'Get an activation code' is followed by instructions: 'To receive an email with a free Nessus Essentials activation code, enter your information. If you already have an activation code, skip this step.' The form contains three input fields: 'First *', 'Last *', and 'Email *'. Below these fields are three buttons: 'Skip', 'Back', and 'Email'. At the bottom, the copyright notice '© 2020 Tenable™, Inc.' is visible.

Hình 9. Nhập thông tin theo yêu cầu để nhận Activation code

Sau khi nhận activation code trong hòm thư điện tử, nhập vào và nhấn *Continue*



The screenshot shows the Nessus Essentials registration interface for entering an activation code. It features the Nessus Essentials logo at the top. The heading 'Register Nessus' is followed by the instruction 'Enter your activation code.' Below this is a single input field for the 'Activation Code *'. There is a checkbox labeled 'Register Offline' which is currently unchecked. At the bottom, there are three buttons: 'Settings', 'Back', and 'Continue'. The copyright notice '© 2020 Tenable™, Inc.' is at the very bottom.

Hình 10. Kích hoạt Nessus

Bây giờ, Nessus đã được kích hoạt, công việc tiếp theo sẽ là tạo tài khoản quản trị Nessus. Nhập tên username, password và sau đó nhấn *Submit*

Hình 11. Tạo tài khoản quản trị Nessus

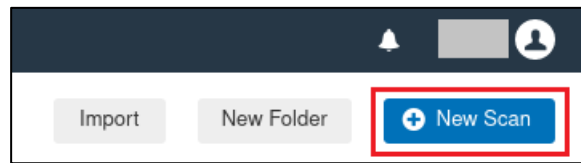
Cuối cùng, chờ quá trình cập nhật và cài đặt các plugin hoàn tất. Quá trình này sẽ mất khá nhiều thời gian.



Hình 12. Cập nhật Nessus

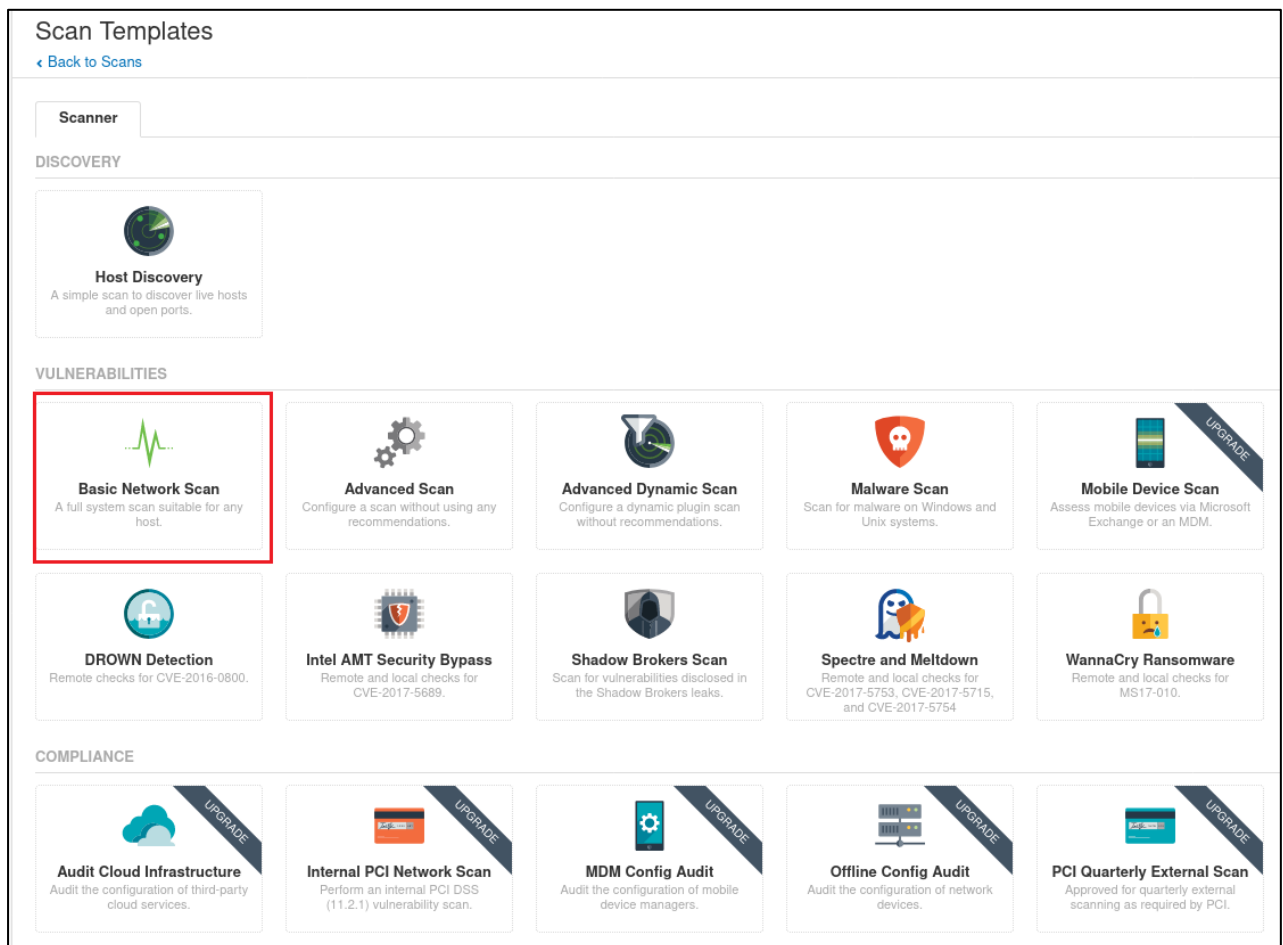
b) Khai báo đối tượng

Sau khi Nessus được cài đặt thành công, thực hiện scan lần đầu tiên. Để bắt đầu, chúng ta bấm vào nút *New Scan*



Hình 13. Tiến hành tạo một lần scan mới

Nessus hỗ trợ nhiều loại quét lỗ hổng khác nhau. Tuy nhiên, trong nội dung bài thực hành này, chúng ta sẽ tập trung vào **Basic Network Scan**



Hình 14. Chọn Basic Network Scan

Nessus sẽ hiển thị màn hình cài đặt cấu hình scan với 2 tham số được yêu cầu khai báo: tên và danh sách các mục tiêu cần scan. Nessus hỗ trợ khai báo mục tiêu sử dụng địa chỉ IP, dãy địa chỉ IP; danh sách FQDN hoặc IP được cách nhau bằng dấu “,”.

Ví dụ, trong bài thực hành này, chúng ta sẽ thực hiện quét máy Metasploitable2, có địa chỉ IP là 192.168.111.150. Chúng ta sẽ nhập “Metasploitable2 – Basic” trong trường *Name* và địa chỉ IP trong trường *Targets*:

New Scan / Basic Network Scan

[Back to Scan Templates](#)

Settings Credentials Plugins

BASIC

- General
- Schedule
- Notifications

DISCOVERY

ASSESSMENT

REPORT

ADVANCED

Name: Metasploitable2 - Basic

Description:

Folder: My Scans

Targets: 192.168.111.150

Upload Targets Add File

Hình 15. Cấu hình scan máy Metasploitable2

c) Cấu hình các định nghĩa quét (Scan Definitions)

Trong mục tiêu bài thực hành này, chúng ta đã chọn template Basic Network Scan, các thuộc tính sẽ được thiết lập mặc định. Tuy nhiên, trong thực tế, chúng ta cần xem xét đến các yếu tố khác như môi trường quét, thời gian, mục tiêu sẽ được quét, ... Một số điều cần xem xét khi sử dụng template Basic Network Scan bao gồm:

- Mục tiêu quét nằm trong mạng nội bộ hay có thể truy cập từ bên ngoài Internet?
- Chúng ta có được phép tấn công brute force thông tin đăng nhập không?
- Scan tất cả TCP và UDP port hay chỉ một số port thông dụng?
- Các kiểm tra nào mà scanner có thể chạy, và kiểm tra nào không thể chạy?
- Scanner chạy quét có thông tin đăng nhập hay không có thông tin đăng nhập?

Mặc định, template Basic Network Scan chỉ thực hiện quét các port thông dụng. Tuy nhiên, bây giờ chúng ta cần thực hiện quét *tất cả* các port. Để thay đổi, click vào *Discovery* phía bên trái của thẻ *Settings*

New Scan / Basic Network Scan

[Back to Scan Templates](#)

Settings | Credentials | Plugins

BASIC

- General
- Schedule
- Notifications
- DISCOVERY**
- ASSESSMENT
- REPORT
- ADVANCED

Name: Metasploitable2 – Basic

Description:

Folder: My Scans

Targets: 192.168.111.150

Upload Targets | [Add File](#)

Hình 16. Truy cập thiết lập Discovery

Trong mục Scan Type, thay đổi giá trị từ Port scan (common ports) thành Custom

Settings | Credentials | Plugins

BASIC

- DISCOVERY**
- ASSESSMENT
- REPORT
- ADVANCED

Scan Type

- Port scan (common ports)
- Port scan (common ports)
- Port scan (all ports)
- Custom**

Use fast network discovery

Port Scanner Settings:

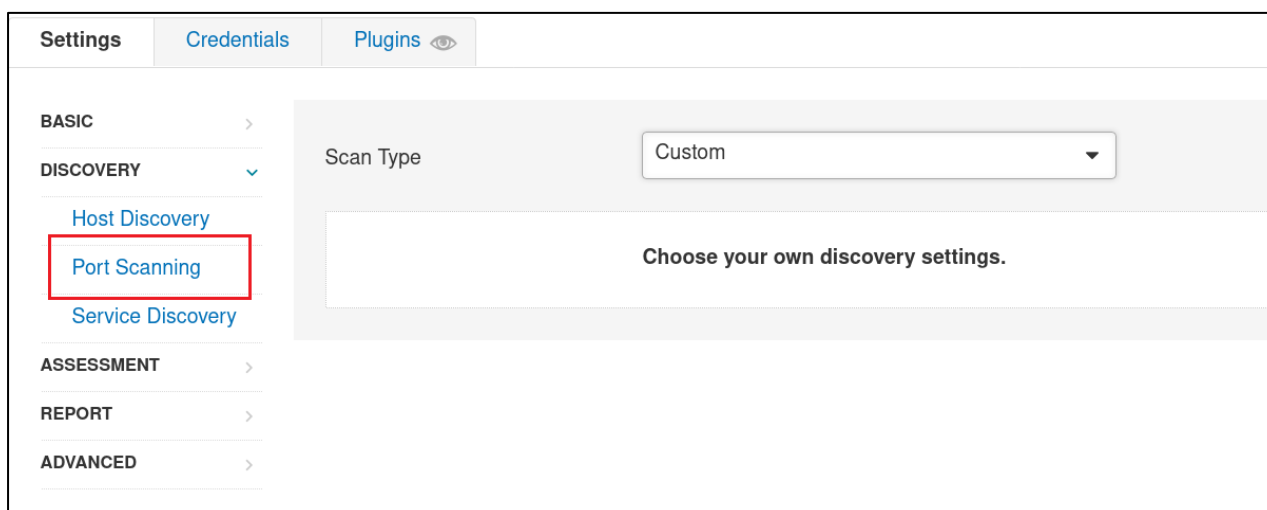
- Scan common ports
- Use netstat if credentials are provided
- Use SYN scanner if necessary

Ping hosts using:

- TCP
- ARP
- ICMP (2 retries)

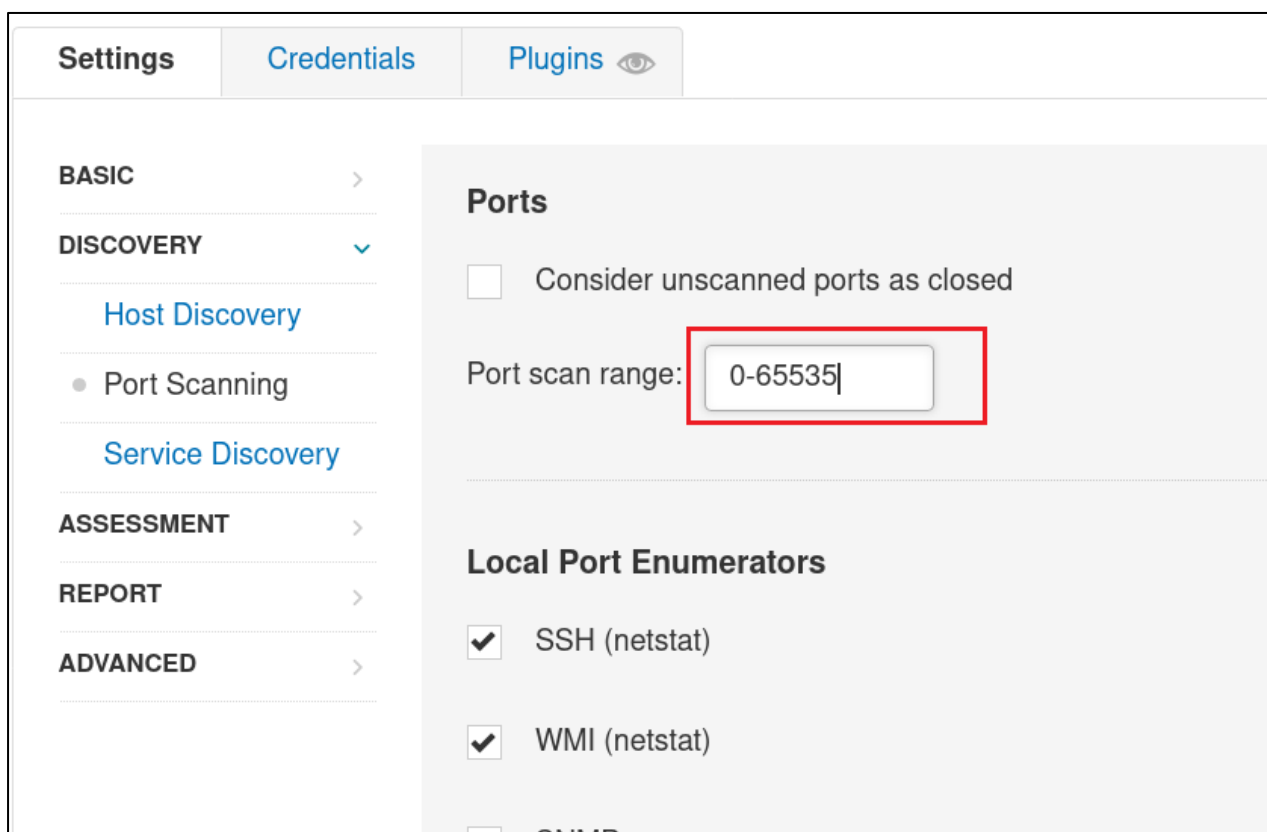
Hình 17. Cấu hình Scanner sử dụng loại Custom Port

Bên trái, chọn Port Scanning ở trong mục con của Discovery để cấu hình dãy port muốn scan.



Hình 18. Chọn tùy chọn Port Scanning

Trong mục *Port Scanning*, chúng ta sẽ thiết lập dãy port muốn scan ở trong phần *Port scan range*. Nhập giá trị “0-65535” để thực hiện quét tất cả các port.



Hình 19. Cấu hình Scanner để quét tất cả các port

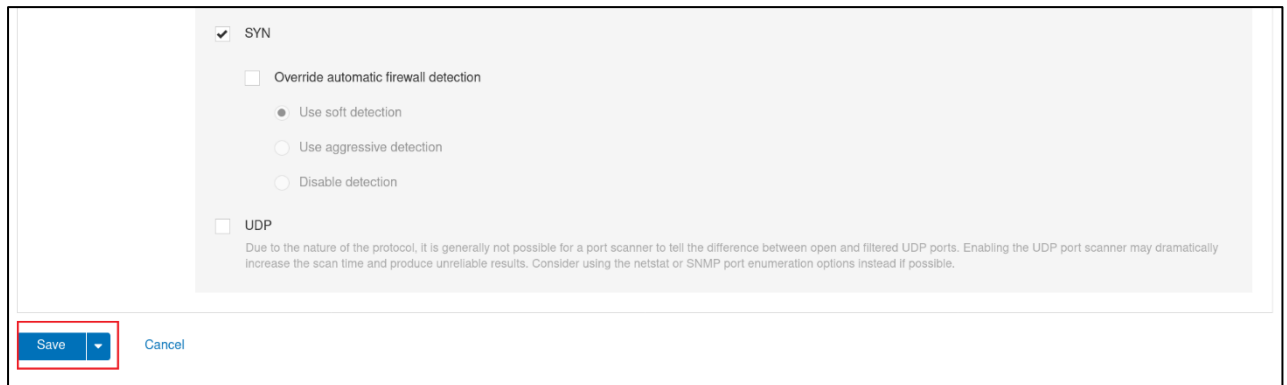
Trong kịch bản này, chúng ta đã chọn định nghĩa scan chỉ quét các port TCP, không quét UDP. Điều này sẽ tăng tốc độ quét, nhưng sẽ bỏ qua các dịch vụ UDP quan trọng trên máy mục tiêu. Trong quá trình quét, chúng ta phải cân nhắc tính ổn định của mạng mục tiêu, phạm vi mục tiêu, thời lượng tương tác và nhiều yếu tố khác khi định cấu hình tùy chọn quét cổng.

Ngoài ra, chúng ta đã không cấu hình bất kỳ thông tin đăng nhập nào, điều đó đồng nghĩa với việc quét mà không cần tài khoản đăng nhập. Thêm vào đó, chúng ta chấp nhận mặc định trong Basic Network Scan, có nghĩa là brute force tài khoản đăng nhập sẽ không được kích hoạt.

Bây giờ, chúng ta đã xem xét hoàn tất tất cả các tùy chọn cấu hình và hiểu (ít nhất là ở cấp độ cao) scanner sẽ làm gì, chúng ta có thể tiến hành chạy quét lần đầu tiên.

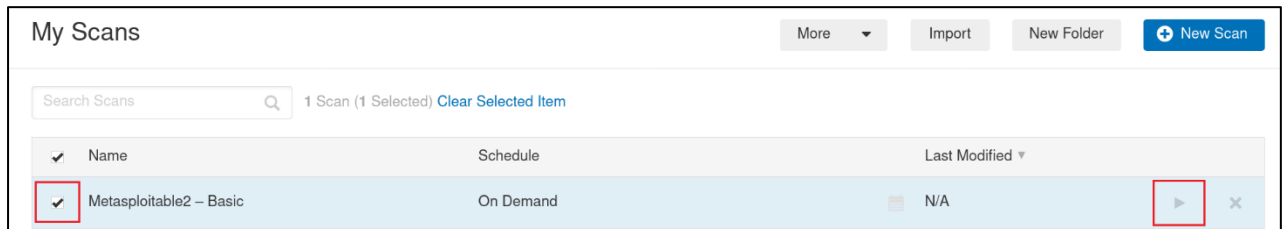
d) Quét lỗ hổng không sử dụng tài khoản chứng thực

Sau khi thiết lập mọi tham số, kéo xuống dưới và chọn *Save*



Hình 20. Chọn save để lưu lại các cài đặt

Sau khi save, quay về mục *My Scans*, chọn vào template “*Metasploitable2 – Basic*”, sau đó chọn *Launch*



Hình 21. Tiến hành chạy quét lần đầu tiên

Trạng thái hiện tại được cập nhật thành *Running* (Hình 22)



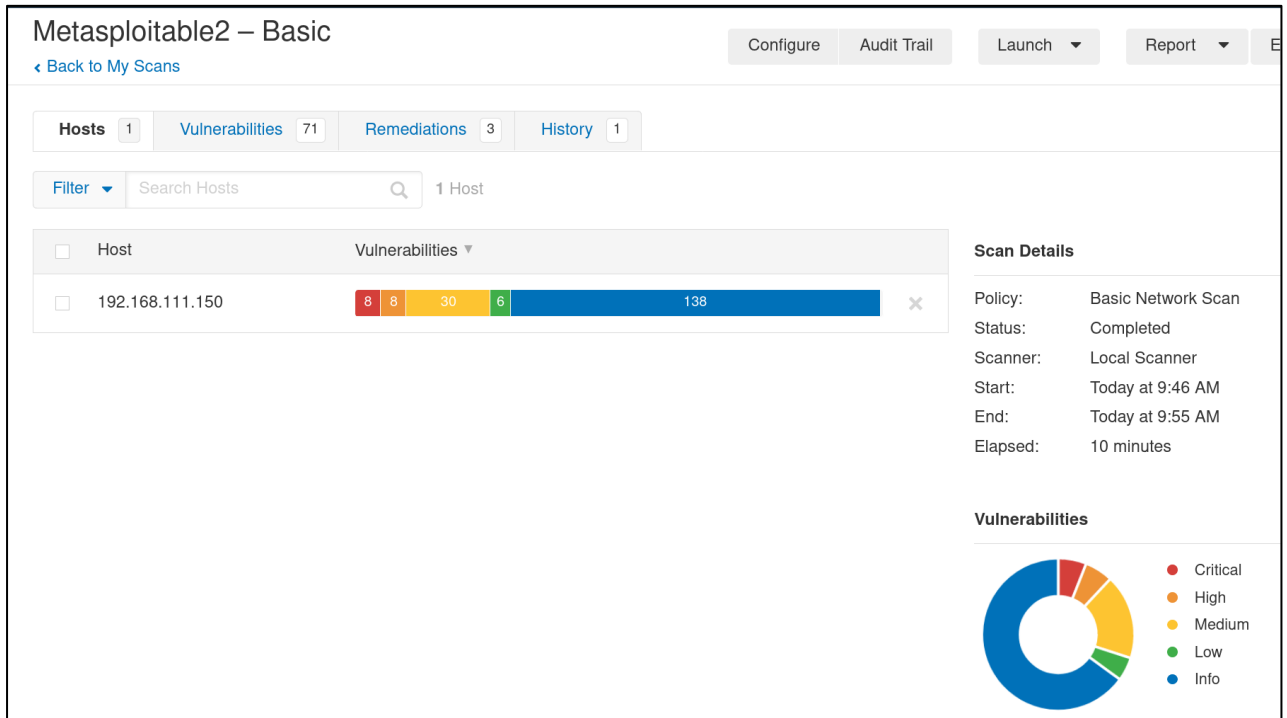
Hình 22. Chờ quá trình scan hoàn tất

Sau khi quét hoàn tất, trạng thái sẽ chuyển sang *Completed* (Hình 23)

Search Scans	Q	1 Scan
☐ Name	Schedule	Completed Last Modified
☐ Metasploitable2 – Basic	On Demand	✓ Today at 9:55 AM

Hình 23. Quá trình scan hoàn tất

Sau khi scan hoàn tất, click vào tên scan, “Metasploitable2 – Basic” để hiển thị danh sách các host được khám phá trong quá trình scan và tóm tắt các lỗ hổng tồn tại.



Hình 24. Giao diện tổng quan

Cho dù chúng ta quét một hay nhiều máy chủ, chúng ta có thể nhấp vào địa chỉ IP hoặc tên máy chủ để hiển thị các lỗ hổng được phát hiện đối với mục tiêu đó, như thể hiện trong Hình 25

Metasploitable2 – Basic / 192.168.111.150

Configure Audit Trail Launch Report Export

Back to Hosts

Vulnerabilities 71

Filter Search Vulnerabilities 71 Vulnerabilities

Sev	Name	Family	Count
CRITICAL	SSL (Multiple Issues)	Gain a shell remotely	3
CRITICAL	Bind Shell Backdoor Det...	Backdoors	1
CRITICAL	NFS Exported Share Inf...	RPC	1
CRITICAL	rexecd Service Detection	Service detection	1
CRITICAL	Unix Operating System ...	General	1
CRITICAL	VNC Server 'password' ...	Gain a shell remotely	1
MIXED	DNS (Multiple Issues)	DNS	6
MIXED	ISC Bind (Multiple I...	DNS	5

Host Details

IP: 192.168.111.150
 MAC: 00:0C:29:FA:DD:2A
 OS: Linux Kernel 2.6 on Ubuntu 8.04 (hardy)
 Start: Today at 9:46 AM
 End: Today at 9:55 AM
 Elapsed: 10 minutes
 KB: [Download](#)

Vulnerabilities

Legend: Critical (Red), High (Orange), Medium (Yellow), Low (Green), Info (Blue)

Hình 25. Xem các lỗ hổng đã được phát hiện

Chúng ta có thể thực hiện lọc các lỗ hổng theo mức độ ảnh hưởng, CVE, khả năng khai thác, và nhiều hơn thế nữa. Để hiển thị các lỗ hổng có thể dẫn đến kiểm soát máy chủ mục tiêu, chúng ta có thể click *Filter* và thay đổi giá trị lọc thành “Exploit Available”, giữ nguyên các giá trị mặc định của “is equal to” và “true”. Sau khi cấu hình xong, click vào *Apply*

Filter Search Vulnerabilities 71 Vulnerabilities

Filters

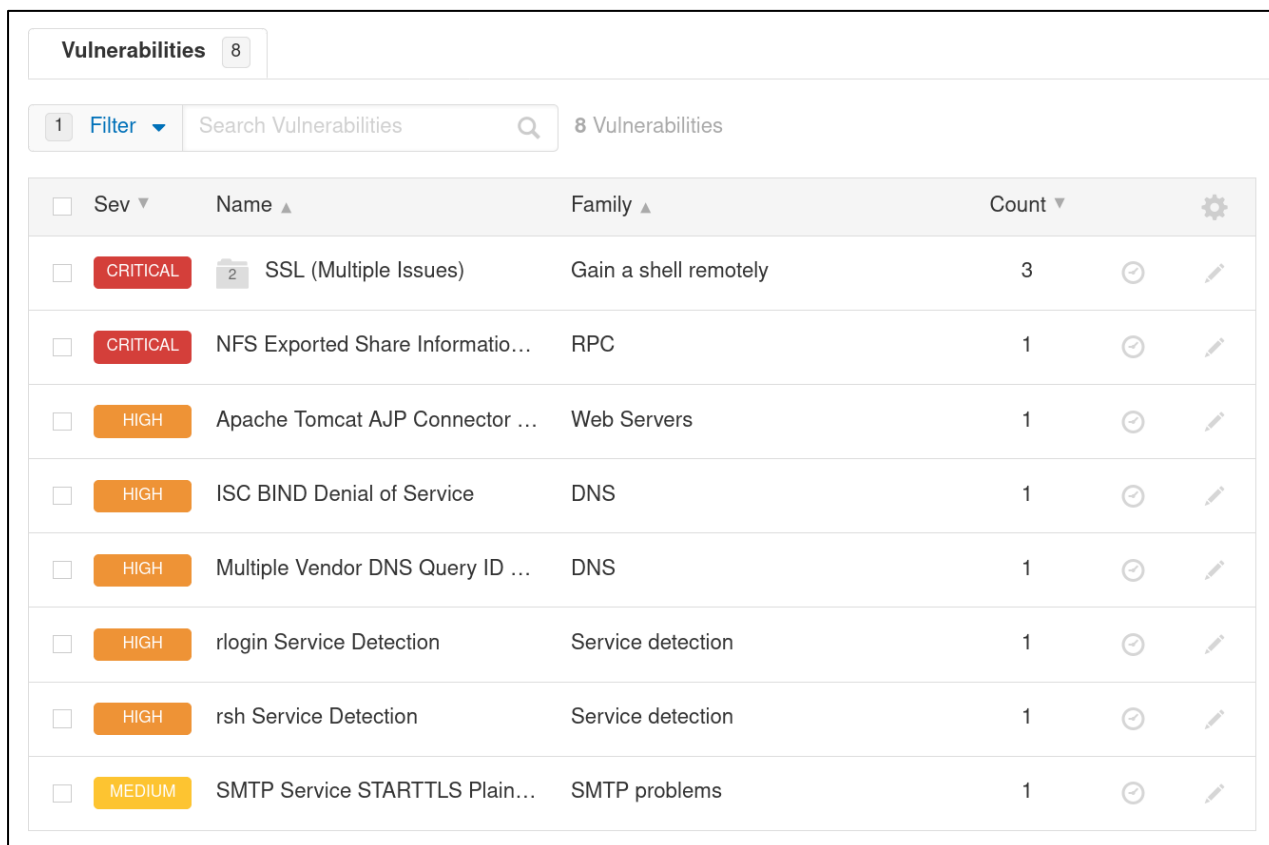
Match All of the following:

Exploit Available is equal to true

Apply Cancel Clear Filters

Hình 26. Lọc các lỗ hổng với các lỗi khai thác

Kết quả lọc sẽ chỉ hiển thị các lỗ hổng theo nhóm được định nghĩa bởi Nessus



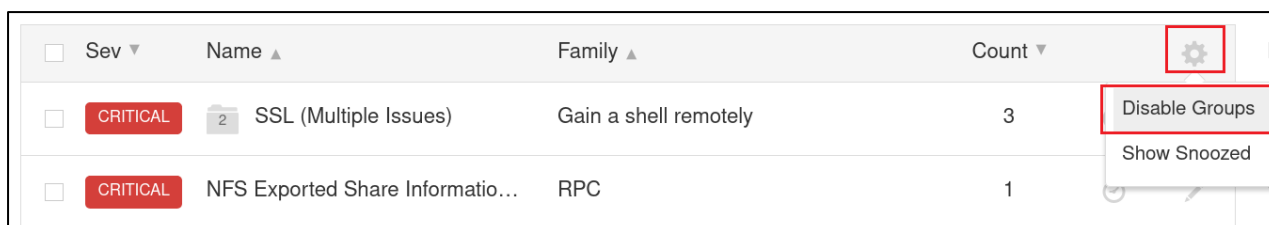
Vulnerabilities 8

1 Filter Search Vulnerabilities 8 Vulnerabilities

☐	Sev ▼	Name ▲	Family ▲	Count ▼		
☐	CRITICAL	2 SSL (Multiple Issues)	Gain a shell remotely	3	🕒	✎
☐	CRITICAL	NFS Exported Share Informatio...	RPC	1	🕒	✎
☐	HIGH	Apache Tomcat AJP Connector ...	Web Servers	1	🕒	✎
☐	HIGH	ISC BIND Denial of Service	DNS	1	🕒	✎
☐	HIGH	Multiple Vendor DNS Query ID ...	DNS	1	🕒	✎
☐	HIGH	rlogin Service Detection	Service detection	1	🕒	✎
☐	HIGH	rsh Service Detection	Service detection	1	🕒	✎
☐	MEDIUM	SMTP Service STARTTLS Plain...	SMTP problems	1	🕒	✎

Hình 27. Danh sách lỗ hổng được phân loại theo nhóm

Trong khi việc gom nhóm có thể hữu ích, chúng ta sẽ click vào biểu tượng hình bánh răng bên góc phải của bảng và chọn *Disable Groups*.



☐	Sev ▼	Name ▲	Family ▲	Count ▼		
☐	CRITICAL	2 SSL (Multiple Issues)	Gain a shell remotely	3	🕒	✎
☐	CRITICAL	NFS Exported Share Informatio...	RPC	1	🕒	✎

⚙️

- Disable Groups
- Show Snoozed

Hình 28. Vô hiệu hóa tính năng gom nhóm

Kết quả sẽ hiển thị danh sách tất cả lỗ hổng trên 1 trang, được sắp xếp theo mức độ ảnh hưởng.

Vulnerabilities 9					
1	Filter	Search Vulnerabilities	Q	9 Vulnerabilities	
☐	Sev ▼	Name ▲	Family ▲	Count ▼	⚙
☐	CRITICAL	Debian OpenSSH/OpenSSL Pa...	Gain a shell remotely	2	🕒 ✎
☐	CRITICAL	Debian OpenSSH/OpenSSL Pa...	Gain a shell remotely	1	🕒 ✎
☐	CRITICAL	NFS Exported Share Informatio...	RPC	1	🕒 ✎
☐	HIGH	Apache Tomcat AJP Connector ...	Web Servers	1	🕒 ✎
☐	HIGH	ISC BIND Denial of Service	DNS	1	🕒 ✎
☐	HIGH	Multiple Vendor DNS Query ID ...	DNS	1	🕒 ✎
☐	HIGH	rlogin Service Detection	Service detection	1	🕒 ✎
☐	HIGH	rsh Service Detection	Service detection	1	🕒 ✎
☐	MEDIUM	SMTP Service STARTTLS Plain...	SMTP problems	1	🕒 ✎

Hình 29. Hiển thị kết quả không sử dụng chế độ gom nhóm

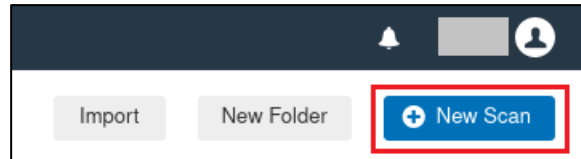
® Bài tập về nhà (yêu cầu làm)

1. Thực hiện lại các bước trên để quét máy Metasploitable 2 không sử dụng tài khoản chứng thực.
2. Bật Wireshark sau đó tiến hành quét và xác định các bước mà Nessus đã thực hiện để hoàn tất quá trình quét.
3. Quét lại nhưng quét thêm port UDP.

e) Quét lỗ hổng sử dụng tài khoản chứng thực

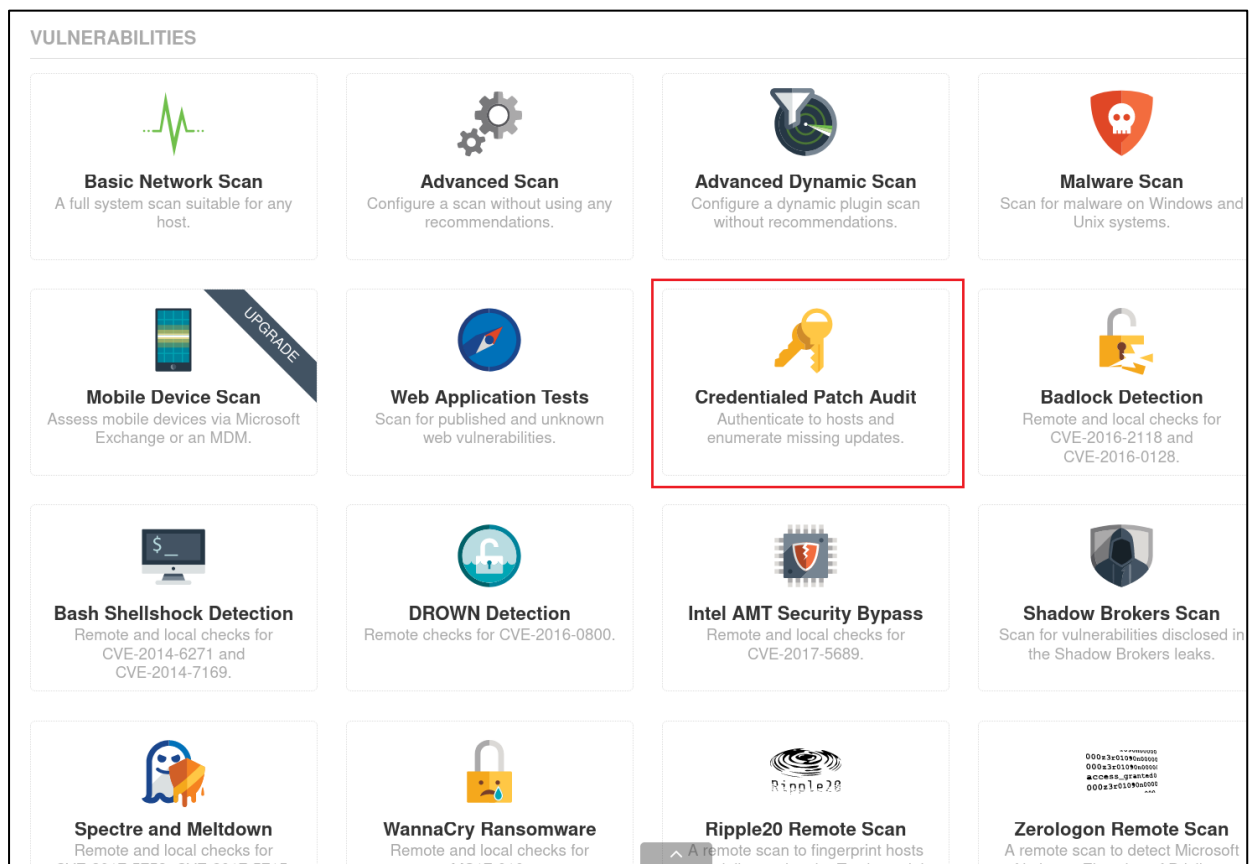
Chúng ta có thể có được nhiều thông tin chi tiết hơn và giảm thiểu các false positive bằng cách thực hiện scan sử dụng tài khoản chứng thực của máy mục tiêu. Tuy nhiên, lưu ý rằng với tư cách là những pentester, chúng ta sẽ không thực hiện scan có tài khoản chứng thực trong hầu hết các trường hợp nếu không có sự cho phép rõ ràng của quản trị viên của mạng mục tiêu do có nguy cơ làm gián đoạn (không chủ ý) tới hệ thống của mục tiêu.

Để bắt đầu, chúng ta sẽ chọn nút *New Scan*



Hình 30. Khởi tạo 1 lần scan mới

Mặc dù tất cả template của Nessus đều chấp nhận thông tin đăng nhập của người dùng, chúng ta sẽ sử dụng template *Credentialed Patch Audit*, được cấu hình sẵn để thực hiện kiểm tra bảo mật cục bộ đối với máy mục tiêu. Template này không chỉ quét các bản vá lỗi còn thiếu ở mức độ hệ điều hành mà còn quét các ứng dụng lỗi thời có thể dễ bị tấn công như leo thang đặc quyền.



Hình 31. Chọn template "Credentialed Patch Audit"

Tương tự như Basic Network Scan, chúng ta cần cung cấp tên và mục tiêu cần quét.

The screenshot shows the Metasploit interface with the 'Settings' tab selected. The 'Authenticating Scan' configuration is visible. The 'Name' field is set to 'Metasploitable2 - Auth' and the 'Targets' field is set to '192.168.111.150'. The 'Folder' is set to 'My Scans'.

Hình 32. Cấu hình cơ bản của *Authenticated Scan*

Tiếp theo, chọn thẻ *Credentials* và chọn loại *SSH*. Trong mục *Authentication method*, chọn *password*, thiết lập username là “msfadmin” và password là “msfadmin”.

The screenshot shows the Metasploit interface with the 'Credentials' tab selected. The 'SSH' category is selected, and the 'Authentication method' is set to 'password'. The 'Username' is set to 'msfadmin' and the 'Password' is set to 'msfadmin'.

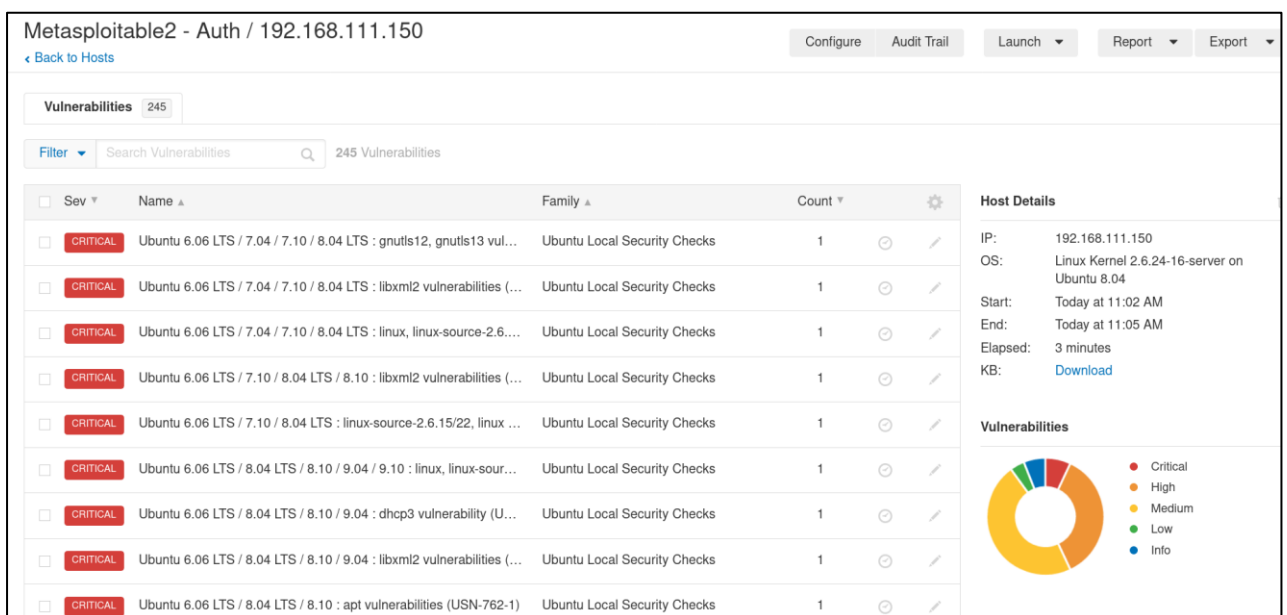
Hình 33. Nhập thông tin tài khoản *SSH*

Cuối cùng, thực hiện quét máy mục tiêu bằng cách chọn *Launch*



Hình 34. Thực hiện scan mục tiêu có sử dụng tài khoản chứng thực

Sau khi scan chuyển sang trạng thái “Completed”, chúng ta có thể click vào tên scan và mở danh sách các host và click vào địa chỉ IP của máy metasploitable 2, kết quả sẽ hiển thị danh sách các lỗ hổng được khám phá có thể được khai thác trên máy chủ.



Hình 35. Danh sách các lỗ hổng khi quét có tài khoản chứng thực

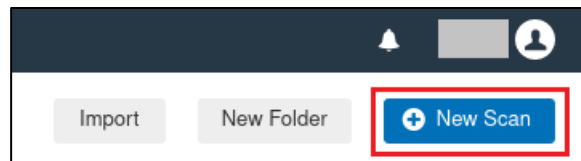
® Bài tập về nhà (yêu cầu làm)

- Thực hiện lại các bước trên để quét máy Metasploitable 2 có sử dụng tài khoản chứng thực.
- Kiểm tra kết quả quét và so sánh với việc quét không sử dụng tài khoản chứng thực.
- Hãy liệt kê các ưu, nhược điểm khi quét có tài khoản chứng thực và không có tài khoản chứng thực.

f) Quét với Plugin được chỉ định

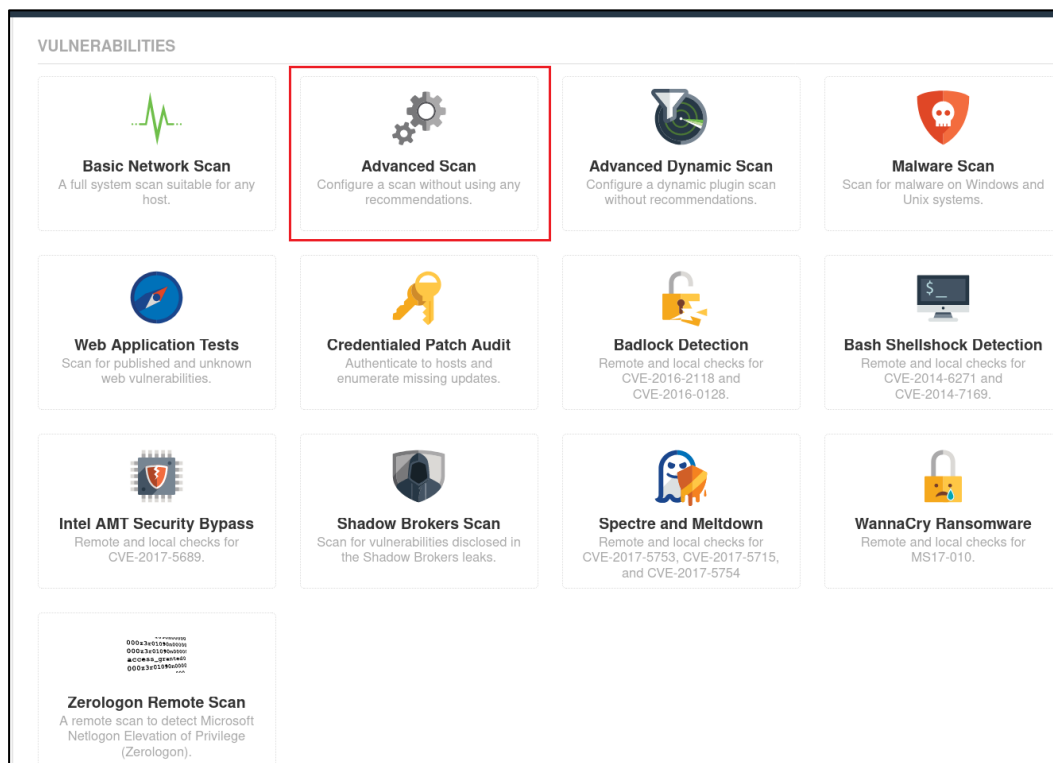
Mặc định, Nessus sẽ kích hoạt số lượng các plugin khi chạy các template mặc định. Mặc dù điều này có thể có ích trong nhiều trường hợp, những chúng ta có thể tinh chỉnh các tùy chọn của mình, ví dụ, chạy một plugin nào đó nhanh chóng. Chúng ta có thể sử dụng tính năng này để kiểm chứng các phát hiện trước đó hoặc nhanh chóng phát hiện ra tất cả các mục tiêu dễ bị khai thác bởi một lỗ hổng trong cùng một môi trường.

Trong trường hợp này, chúng ta sẽ chạy plugin *NFS Exported Share Information Disclosure*. Để chạy scan cho một plugin, chúng ta lại bắt đầu bằng *New Scan*



Hình 36. Khởi tạo scan mới

Lần này, chúng ta sẽ sử dụng template *Advanced Scan*. Không giống với các template *Basic Network Scan* và *Credentialed Patch Audit* đã được sử dụng trước đó, template *Advanced Scan* không sử dụng các đề xuất cho các cấu hình quét. Tuy nhiên, template này cung cấp một bộ các giá trị mặc định “Nâng cao” thường bị ẩn hoặc không khả dụng đối với các template khác. Lưu ý rằng *Advanced Scan* cho phép chúng ta chọn các plugin riêng lẻ, một tùy chọn không có sẵn cho hầu hết các template khác.



Hình 37. Chọn template “Advanced Scan”

Tương tự, cũng đặt tên và đối tượng cần scan.

The screenshot shows the 'Settings' page in Metasploit, specifically the 'Credentials' tab. On the left sidebar, the 'BASIC' section is expanded, and the 'General' option is selected. The main content area shows the following fields:

- Name:** Metasploitable2 - Individual (highlighted with a red box)
- Description:** (empty text box)
- Folder:** My Scans (dropdown menu)
- Targets:** 192.168.111.150 (highlighted with a red box)
- Upload Targets:** (button)
- Add File:** (button)

Hình 38. Thiết lập tên và đối tượng cần quét

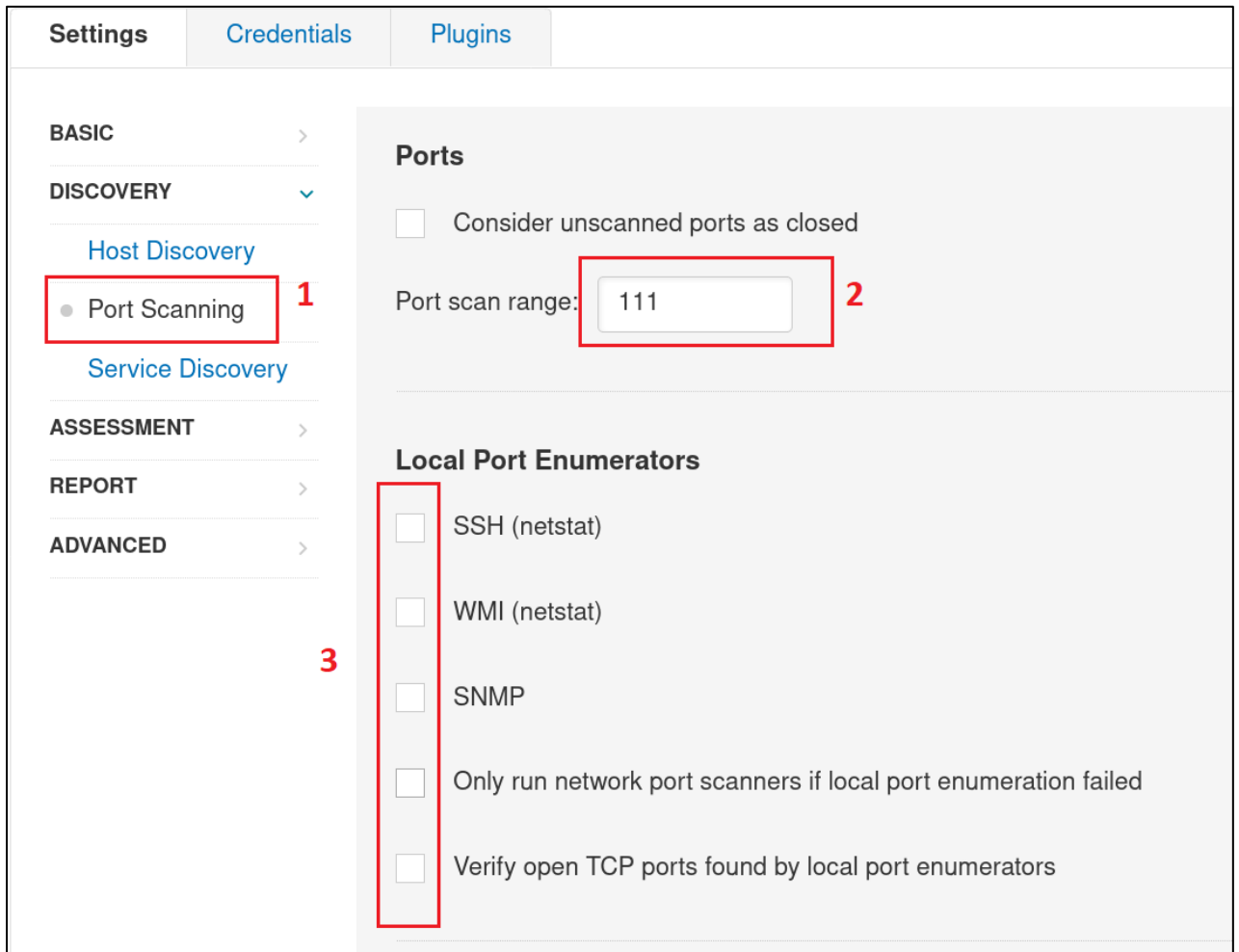
Để tiết kiệm thời gian và ít để lại dấu vết, chúng ta sẽ tắt *Host discovery*, vì chúng ta biết được host vẫn còn hoạt động.

The screenshot shows the 'Settings' page in Metasploit, specifically the 'Credentials' tab. On the left sidebar, the 'BASIC' section is expanded, and the 'DISCOVERY' option is selected (highlighted with a red box and labeled '1'). Under 'DISCOVERY', the 'Host Discovery' option is selected (highlighted with a red box and labeled '2'). The main content area shows the following settings:

- Remote Host Ping:** Ping the remote host (toggle switch is OFF, highlighted with a red box and labeled '3')
- Fragile Devices:**
 - ☐ Scan Network Printers
 - ☐ Scan Novell Netware hosts

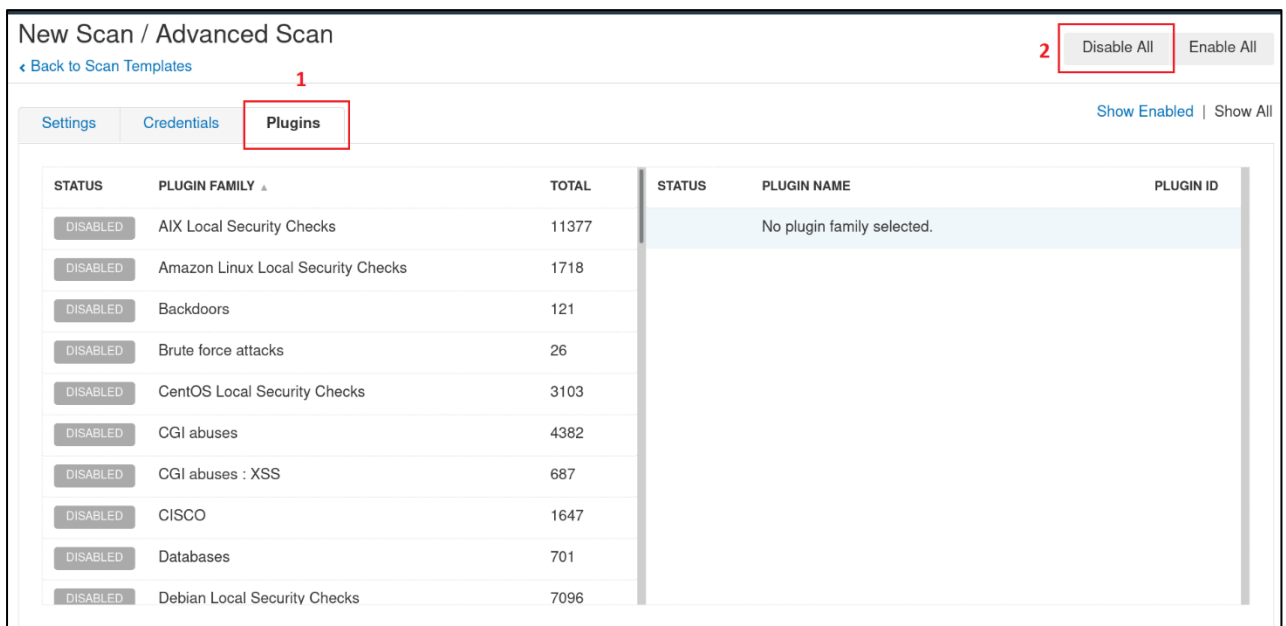
Hình 39. Tắt tính năng Host Discovery

Vì chúng ta chỉ scan dịch vụ RPC và biết rằng RPC chạy trên TCP port 111, nên chúng ta chỉ scan duy nhất port này.



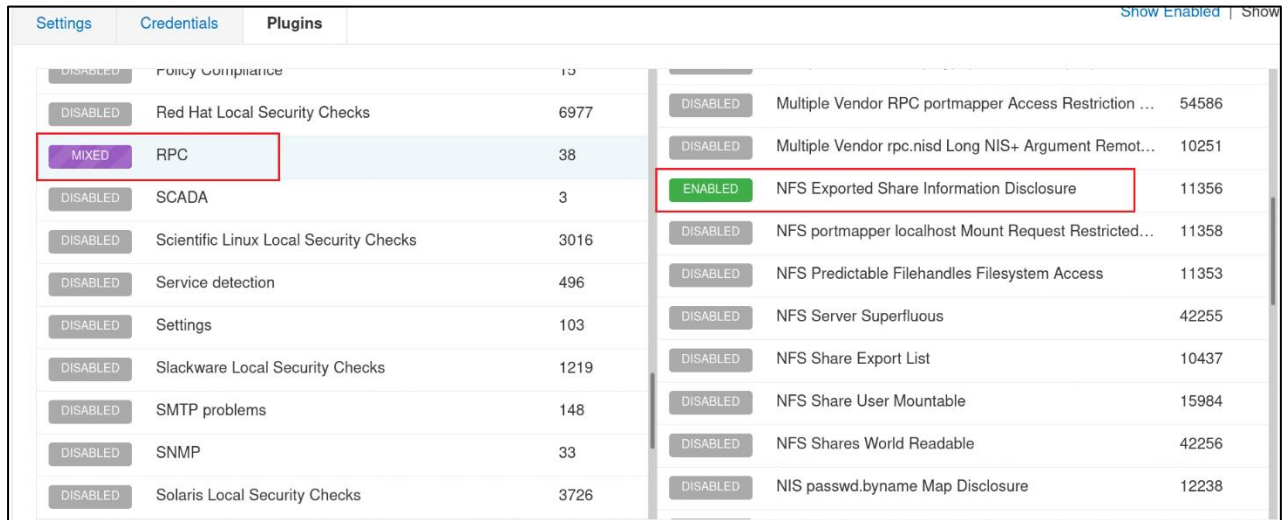
Hình 40. Tắt hết các port không cần thiết

Sau khi giảm thiểu tối đa các tùy chọn scan, bây giờ tiến hành chọn plugin. Chọn thẻ *Plugins* và click vào *Disable All* ở góc phải



Hình 41. Tắt hết tất cả các plugin

Để tiến hành quét NFS shares, chúng ta sẽ di chuyển đến “RPC” bên cột bên trái và thiết lập “NFS Exported Share Information Disclosure” ở cột bên phải thành *Enabled*



Hình 42. Bật plugin NFS

Bây giờ ta đã cấu hình xong, tiến hành quét. Click vào *Launch*.



Hình 43. Tiến hành quét NFS

Sau khi trạng thái quét chuyển sang “Completed”, chúng ta có thể click vào tên scan, sau đó địa chỉ IP máy mục tiêu. Di chuyển đến lỗ hổng Critical duy nhất và click vào để hiển thị chi tiết thông tin lỗ hổng.

CRITICAL

NFS Exported Share Information Disclosure

>

Description

At least one of the NFS shares exported by the remote server could be mounted by the scanning host. An attacker may be able to leverage this to read (and possibly write) files on remote host.

Solution

Configure NFS on the remote host so that only authorized hosts can mount its remote shares.

Output

```

The following NFS shares could be mounted :
+ /
+ Contents of / :
- .
- ..
- bin
- boot
- cdrom
- dev
more...

```

Port ▲	Hosts
2049 / udp / rpc-nfs	192.168.111.150

Hình 44. Xem kết quả scan với chỉ 1 plugin duy nhất

® Bài tập về nhà (yêu cầu làm)

- Thực hiện lại các bước trên để quét máy Metasploitable 2 sử dụng plugin NFS Exported Share Information Disclosure
- Chạy Wireshark hoặc tcpdump trong suốt quá trình scan sử dụng 1 plugin duy nhất. Liệt kê các port khác mà Nessus thực hiện scan, mà không phải port 111? Tại sao Nessus lại scan các port khác, trong khi chúng ta đã chỉ định chỉ scan duy nhất 1 port là 111?
- Mô tả cách làm để ngăn chặn việc Nessus scan port khác không phải là port được chỉ định?
- Thực hiện quét lại sử dụng 2 plugin khác.

2. Bài tập nhóm

® Bài tập về nhà (yêu cầu làm)

11. Sinh viên/nhóm sinh viên tìm hiểu 1 trong các công cụ quét lỗ hổng tự động sau đây, và viết báo cáo kết quả theo như các phần đã chia ở bài tập 1:

- OpenVAS (<https://www.openvas.org/>)
- Tsunami (<https://github.com/google/tsunami-security-scanner>)
- Rapid7 Nexpose (<https://www.rapid7.com/try/nexpose/>)
- Qualys Community Edition (<https://www.qualys.com/community-edition/>)
- Arachni (<https://www.arachni-scanner.com/>)
- Sn1per (<https://github.com/1N3/Sn1per>)
- Trivy (<https://github.com/aquasecurity/trivy>)
- Jok3r (<https://github.com/koutto/jok3r>)

C. YÊU CẦU & ĐÁNH GIÁ

1. Yêu cầu

- Sinh viên tìm hiểu và thực hành theo hướng dẫn. Có thể thực hiện theo nhóm (2 sinh viên/nhóm) hoặc thực hiện cá nhân. Đăng ký nhóm cố định từ buổi 1.
- Sinh viên báo cáo kết quả thực hiện và nộp bài bằng **1 trong 2 hình thức**:

a) Báo cáo chi tiết:

Báo cáo cụ thể quá trình thực hành (có ảnh minh họa các bước) và giải thích các vấn đề kèm theo. Trình bày xuất file PDF theo mẫu có sẵn tại website môn học.

b) Video trình bày chi tiết:

Quay lại quá trình thực hiện Lab của sinh viên kèm thuyết minh trực tiếp mô tả và giải thích quá trình thực hành. Upload lên **Youtube** và chèn link vào đầu báo cáo theo mẫu. **Lưu ý:** Không chia sẻ ở chế độ Public trên Youtube.

Đặt tên file báo cáo theo định dạng như mẫu:

[Mã lớp]-LabX_GroupY

Ví dụ: [NT101.I11.1]-Lab1_Group1

- Nếu báo cáo có nhiều file, nén tất cả file vào file .ZIP với cùng tên file báo cáo.
- Nộp báo cáo trên theo thời gian đã thống nhất tại website môn học.

2. Đánh giá:

- Sinh viên hiểu và tự thực hiện được bài thực hành, đóng góp tích cực tại lớp.
- Báo cáo trình bày chi tiết, giải thích các bước thực hiện và chứng minh được do nhóm sinh viên thực hiện.
- Hoàn tất nội dung cơ bản và có thực hiện nội dung *mở rộng – cộng điểm* (với lớp ANTN).

Kết quả thực hành cũng được đánh giá bằng kiểm tra kết quả trực tiếp tại lớp vào cuối buổi thực hành hoặc vào buổi thực hành thứ 2.

Lưu ý: Bài sao chép, nộp trễ, *“gánh team”*, ... sẽ được xử lý tùy mức độ.

HẾT

Chúc các bạn hoàn thành tốt!